Static Application Security Testing report

Semgrep scan of the Entra ID Posture Scanner

Tool	Semgrep 1.182.1 (open-source CLI, offline, metrics off)
Date	2026-10-24
Target	Entire repository: application, tests, tools, docs, CI workflows, launchers
Rule sources	Official semgrep-rules repository (github.com/semgrep/semgrep-rules): python, javascript, generic, yaml, bash
Scope proof	299 files scanned, 13,777 lines; 0 files skipped by semgrep
Engine summary	Scanning 70 files tracked by git with 966 Code rules
Findings	0 total (ERROR 0, WARNING 0, INFO 0); scan errors: 0

Result

No findings were reported. Errors during the scan: none.

Files by type

(none)	207
.0	4
.1	2
.3	2
.bat	1
.js	1
.md	10
.ps1	1
.py	47
.sample	14
.toml	1
.tsv	1
.txt	2
.yml	6

Findings and triage

None.

Appendix A - files scanned (proof of coverage)

.git\COMMIT_EDITMSG | .git\FETCH_HEAD | .git\HEAD | .git\config | .git\description | .git\hooks\applypatch-msg.sample
| .git\hooks\commit-msg.sample | .git\hooks\fsmonitor-watchman.sample | .git\hooks\post-update.sample |
.git\hooks\pre-applypatch.sample | .git\hooks\pre-commit.sample | .git\hooks\pre-merge-commit.sample |
.git\hooks\pre-push.sample | .git\hooks\pre-rebase.sample | .git\hooks\pre-receive.sample |
.git\hooks\prepare-commit-msg.sample | .git\hooks\push-to-checkout.sample | .git\hooks\sendemail-validate.sample |
.git\hooks\update.sample | .git\index | .git\info\exclude | .git\logs\HEAD | .git\logs\refs\heads\docs\claude-md |
.git\logs\refs\heads\fix\ci-semgrep-zap | .git\logs\refs\heads\fix\ci-workflows | .git\logs\refs\heads\main |
.git\logs\refs\remotes\origin\HEAD | .git\logs\refs\remotes\origin\dependabot\github_actions\actions\checkout-7.0.1 |
.git\logs\refs\remotes\origin\dependabot\github_actions\actions\setup-python-7.1.0 |
.git\logs\refs\remotes\origin\dependabot\github_actions\trufflesecurity\trufflehog-3.99.3 |
.git\logs\refs\remotes\origin\dependabot\github_actions\zaproxy\action-baseline-0.15.0 |
.git\logs\refs\remotes\origin\docs\claude-md | .git\logs\refs\remotes\origin\fix\ci-semgrep-zap |
.git\logs\refs\remotes\origin\fix\ci-workflows | .git\logs\refs\remotes\origin\main |
.git\objects\00\4691959b64bda9d1a41845aa5030e9fc66f5e0 | .git\objects\02\beae52c5b136a872dade7ecaa4ceb7eff9a837 |
.git\objects\03\8dc5854f68b58b43862cd951a6477c1bc71090 | .git\objects\03\a28ba6785868fbf538317a6c340cba48faf938 |
.git\objects\07\6cd42771a1d97211d02bc162574c4cbc1c1a46 | .git\objects\0a\894094fb728d64cec9515a6770477f1d6bca74 |
.git\objects\0b\7ac37d8fe98ccf6c4393e2fa66d5233bc09f71 | .git\objects\0b\eddda229adebca0c90f5977845f28b73e99dae |
.git\objects\0c\76e40bdbd11eb3398a852b68c791e4ab2256a7 | .git\objects\0f\befce1ffc5976fefc516b3447f040997184f37 |
.git\objects\11\ecb555929077e07a76e82ee0c513ba82eb47be | .git\objects\14\48deaff6174f5859d3ba06e6c08f51f73b12ef |
.git\objects\1b\ca87f2f68cc602f13f5f229e80f17815823d3e | .git\objects\1c\ae5c9aa0fafedda070228a429ba179404b5585 |
.git\objects\1c\d5c4ecea6dd2726c5c5f6176b7918c4b676d97 | .git\objects\1d\490975ab6c77ce40c6a693b489cfb1865d6a50 |
.git\objects\1f\db822c59fe6418b05f5856f998714ff0343aa2 | .git\objects\20\f76da1a643f59631194237cf8411d4a567dce5 |
.git\objects\22\e63a5633046638a4b47eb1e3a27a743fe6beef | .git\objects\22\eeb72f44db7b48abffde737a3f55b90b0b84e4 |
.git\objects\25\a3cd0f691199f53c0848290a77e369eb7149ea | .git\objects\25\f475b7f167e3fe7ab5855e1c44bac27b1fbf71 |
.git\objects\26\31f233a7180ef8b3c20a30a392fdafc1b5d6ad | .git\objects\27\0f1ba1c638832b38b8305b6c78788f70a8a0be |
.git\objects\2a\403a66b7aa4c8bf400a6a550ea4962cb088c04 | .git\objects\2a\fe1ef0225bb6b560c116f8b24306271e85ed9d |
.git\objects\2c\1ffd5e2335554bc9cfa82f630d7a2b721ae7ee | .git\objects\2e\14ff6d20f38ac257ae772b9f35a6bac72c1b43 |
.git\objects\2e\22a8074b9c5a2847dd144ebfda83da00083a2c | .git\objects\2e\2bf202de47c7d7f0b162e15625fe55c44db0de |
.git\objects\2e\b50525d6b70ff7ac72bf07738f20cd6f07c83e | .git\objects\2f\4f4f338de2508280933ec8806c787b01fb9ac9 |
.git\objects\30\ab82aec0ae0de7fbeafe229974a8c7e5300be5 | .git\objects\31\7be2b7e48414801d5a4febfbdb637aba310ead |
.git\objects\31\8fe3d50ce8bd8faad87088d7112dee354222d8 | .git\objects\32\45b245b556145766e28b1bd43882ec451b7f07 |
.git\objects\36\d26e095ef1bdf354622d303b1a1250598c9349 | .git\objects\37\db2f2a259cbc0bcbdef279c2e6c0e6be501576 |
.git\objects\38\242ef3fd2b50562cc6921f9427a32a66a02583 | .git\objects\39\dd589324aabe8011648a72a3419a1c44c5d6d6 |
.git\objects\3c\7d393a2577b7fe4751a0f91bcca619edec7522 | .git\objects\3d\9025ab4adfb6477111085be3009dc83993efbd |
.git\objects\3d\f42e0c3d6c921a551f91c01c038bc9a107ef16 | .git\objects\3f\56ae9b54eef7c30dd7736af79352dc57de8e9f |
.git\objects\3f\6ff3b46e1b0ec1be92230c1c787ca837ceec12 | .git\objects\42\87b9277c193f44ae97a677020753a4464b7ae7 |
.git\objects\44\66efcfd4d99f110948192be005ad68a24f8662 | .git\objects\46\101a74a1ec9a7b6b461318f5f231dd831e1516 |
.git\objects\46\b020ad0943f034d68e678e1af7e197b7028fc0 | .git\objects\48\7d53749f1b569398f1f9cb4e192f5ae249d04e |
.git\objects\49\8f19d3919c888b12f384fb03e16878014b3ae9 | .git\objects\49\98ee789b9af2a5c93cc2c51fc280ac9373e3a0 |
.git\objects\49\a52bd4c6f6a88c7fa0d01465c5be3933cdee5e | .git\objects\49\b34c9abacd4261abdeb1aa1f97e3d418069f0a |
.git\objects\4a\a58e5d6dd784822bed116411421e67fccf91d6 | .git\objects\4b\57b8833beed5d96ce9a3000ce9364e6e926cf8 |
.git\objects\4b\f57e828496a35e54c6d827990bbf81b9c98182 | .git\objects\4c\f0c27dcf8276776e7d5f63f081757806fe7346 |
.git\objects\4d\d45b3b83da770007b717112039bff8c337e63b | .git\objects\50\8737d72e5ea25dcb13f291a85c09145869db79 |
.git\objects\50\b805b6bf28659ccc84380d21aa79da69f13351 | .git\objects\51\69d2246663b86f96f06de9018ab86363e0d371 |
.git\objects\52\e1c40772d8eea1bbf49190c3d48108d9bf14bc | .git\objects\52\f1ce91e50f1f667ed39c4aae963413a36883fb |
.git\objects\53\1fb4101ae0c28a8fb4e46f36374a9f11f783c8 | .git\objects\53\407995056121a8787bdf35cbab3edfd2befbf2 |
.git\objects\56\499027fedfe64abd6b2050b5a47cd91f7faecb | .git\objects\57\fbc7c22f6b94646d7a882a096f243e4b40fcfe |
.git\objects\59\779f5dba61ecb63bd52a384538631de28e810f | .git\objects\5a\f081776a347c1dabde1f04be107c9b1d34e4f1 |
.git\objects\5b\6d76fb934209b89e772ab637c8ba5aa09eea47 | .git\objects\5e\24c92d3f949c66d1b8a36d13a15244c00660c8 |
.git\objects\5f\888a08843c91e6bbf5d357c255f49291547e8c | .git\objects\5f\cb4d9633da84858ff5ca689ed015eee2ac827f |
.git\objects\61\254470ff47e10becdd52a3794cd611e2d3d9b6 | .git\objects\61\35f47186197303a18a2e9903015e552fb4733a |
.git\objects\62\693103bd7602a96b86e7a13e65970c518cf822 | .git\objects\63\c2db905e78896d1fc61944817c9c88e2d11109 |
.git\objects\65\30986c91f21c89b8283ca616a066e87217dd11 | .git\objects\6e\250f387133d50a162c51ee9bfef777bfd24d42 |
.git\objects\6f\f788e9f55f28e9ae7bbc3c482d3b2d29159e46 | .git\objects\71\cc7d1da866638e6438dc973fbb5e355d66c9b1 |
.git\objects\74\b098dde0a8c7f188853eef5fdd35696ccf2e50 | .git\objects\75\557298032ef7b14c36720b82674805b590ef84 |
.git\objects\76\a6a2457e68588a97142229ce6ccbb919a3de6b | .git\objects\78\1e822ad5e4544766bdfaadae080bcebf1026c7 |
.git\objects\78\503b7f35ee07b3ad64514ec4f92a5c0793af00 | .git\objects\78\f5b6c7384b10e19082244ce881e6733c99ad69 |
.git\objects\7a\35772f8410d146f83f9a09840f762def81ad3d | .git\objects\7c\672c72333a4ebe7c746b812eaec552653d1516 |
.git\objects\7d\b0c0e7bb508dc9cdb574b92ab3f2ae451485ff | .git\objects\7d\e528651a5f8a527c8fa8bce07a7372e25c2911 |
.git\objects\80\d6fc2624293b3b6e69d2971b2068f99d46927e | .git\objects\80\f601190c344995f01a8773b4130f2b6e6712aa |
.git\objects\84\6322e819e9c772c3a5723459b7112ac9b00426 | .git\objects\86\3d881d05e2326fe61daa388de31463bf57382a |
.git\objects\88\62552d3be03ba2f22db5c8827a633d90e524ff | .git\objects\88\79962538ad587f6a1ca90241fab4975e91f050 |
.git\objects\8a\be78ab872b24457e6157dfb8064c912632f6c5 | .git\objects\90\47e4125c04eae2ab0707f276c98c0501220545 |
.git\objects\90\b65e10a639931439a7fe62c6ea898ae0ecdd0b | .git\objects\91\99ad6602da8c08186d321466dd4dd0ecd32400 |
.git\objects\92\5bf3d71d6f979b36769afb9371d1129c4e16c6 | .git\objects\92\6cfaa9e7ce373cd333f571bd8d89ad84022cab |
.git\objects\94\665dc3dd7f9baf9d25693b83cf9db5484dcb1b | .git\objects\99\733d591309945f814d2d702023295b720aab84 |
.git\objects\9a\1a640553967e70ba7fcb5b637e14331893126c | .git\objects\9a\726fdd1cdc6ad2f15efb269841f4263cc1139a |
.git\objects\9b\497be209fd72230a989f2768275a5fc2aba25e | .git\objects\9c\d61a78f04474a01565fb22497cff7d6f8af5ee |
.git\objects\9d\fca635ee82c5874fd12b88e03845d6e8e9c78b | .git\objects\9e\d0aca1fb63a26dbf3c96c1f5a84a231f67b721 |
.git\objects\a0\58c0666d4a0f187ecdd74d60033b7197f64880 | .git\objects\a0\5d0f81173b8a723c5190fa028b034961438a79 |
.git\objects\a2\5732499ff6ec6e568a621cd637d7257c463fef | .git\objects\a2\c3e1ce4c7f6578cc1cd88fa00db2441cdc0a33 |
.git\objects\a7\ace309eb6010234bbf8ca0d0335d2bb4ea8ff5 | .git\objects\a7\bbd3a97369093037fd259cd2bae06598282557 |
.git\objects\a8\2df80bdec11ee684c877fc864742886cad450e | .git\objects\a8\fa99e1143a3f4abcc8d4366e7cdf68ded2e15d |
.git\objects\ac\c72aa6ec39a7339da57c484fdbf88cf8d7ce2b | .git\objects\ac\cc7351946fe1d9468e8a13759668c2781e326a |
.git\objects\ad\0edaad2b7847808672eed61c3c238863fd2361 | .git\objects\ad\729cc49960edd13e27bac4d13093b63cd62348 |
.git\objects\ae\11f993c49360d494089d6863b66d4130e09f5a | .git\objects\b4\e90e7a23ba7b34197a7ef223c8837de311283d |

.git\objects\b6\204aeca5b7cd6867d2225db6bde7333b43f471 | .git\objects\b8\182601d50e863c718721f91229dda2f02a86af |
.git\objects\ba\7ad7313304bd07af0c9a3b7ca362fa94cb62fc | .git\objects\ba\a93fbcab7022f4dc6ca78dd27772a0d4d04367 |
.git\objects\bc\ecbcc272f3991c83ac37d83d52105b4c55c132 | .git\objects\be\d791189b35fa07eccff637a96ae72f215d116f |
.git\objects\c1\1d7aa003a86606c642866073b4880ae3190454 | .git\objects\c1\65db5c7a462f2b368b02987e6357b423115a72 |
.git\objects\c3\ec7e6f0940ca4e235a24673434a67f4405afb2 | .git\objects\c5\e4ef787223da211e52649ac2da38ee1a1a66f9 |
.git\objects\c7\221ee7080a91485113990bd9c5bf976880cfa0 | .git\objects\cb\ccc95aea31f2614a74d71dd673266b4e2e70d1 |
.git\objects\cb\d920f6b3ba719f191d20703765bdeef260b138 | .git\objects\d0\204fb67ad3c58411bf51b12333f87e98fb7deb |
.git\objects\d3\1ae9469a60535cbc58ed7b1758b347454713b9 | .git\objects\d3\78a0a37cff452147199aaeb59f86e8e37f27dc |
.git\objects\d4\7aacfe3e38e94bbb24dcf126186007d84030e6 | .git\objects\d5\2cc570c359fe8452f6e484777a904349b09f54 |
.git\objects\d5\be974b98ac3cb58ffc1f1b36237f74614f8ca8 | .git\objects\d5\cec4380f8ab40467ab77653f19a1960294538e |
.git\objects\d7\d2ecee1cd7b46d55d1a21fa4c9e20da232a763 | .git\objects\d9\7f66eb41bba98727d1d654a43bb1a0a18d7658 |
.git\objects\d9\d3159390a2ffe789da2ac9a83f6f6b035b1630 | .git\objects\da\6dce8926707ebf95d936e65a3c4db34c591c77 |
.git\objects\dc\12ce3817046c60764d9f86427d3993c09a5e78 | .git\objects\dc\782a5de217085589c1ecb2fb18d6776f986cad |
.git\objects\dc\f6350a13dfd5e25586c78e83d5bc137d198e03 | .git\objects\de\6847ebdf148fa9042e204e2223adbd46601eba |
.git\objects\e0\4d949a6afc361245b6aeeb2d7e9768c37ba8b9 | .git\objects\e3\be8c14e7a6f4c49609f8d0bb397991e07229fd |
.git\objects\e6\01d488e0eeeca5fd44bacc8e8754c4d47de696 | .git\objects\e8\7708c2283d0a9c13d4853397f345009a451c23 |
.git\objects\eb\91c79282507d70756f4a4a689674a9682776c9 | .git\objects\ec\a248e534b10397880bc9c7c40645ab4691c52e |
.git\objects\ed\d59c89d418084b3ddb6eafbc339ec0964d5ef5 | .git\objects\f0\2afa263310c48dcf0b120a2b7ae7e427f25eb8 |
.git\objects\f0\76a4ade4ba5800b16e7f975f05fd8689ad41bd | .git\objects\f0\85bd00c4f0c6babee26b8a1c9f2ed0bcad7579 |
.git\objects\f1\00375a52a014286af04b3300cc5a4cec9d11b1 | .git\objects\f1\0f833f3c6b5e820011982356b35805428533bb |
.git\objects\f1\2b8fe25428c3a15c2b0df6001fa8552737afdf | .git\objects\f1\6ea65e4e4e1b903b3b7ec6ef6364a4445a9fd5 |
.git\objects\f5\498110811b6e033e855ee0a34124fae56d7f0e | .git\objects\f6\b1d30fc0e43dde3a0a64d700cdad9abb400a71 |
.git\objects\f6\e656e1899cf602d8e12c78ba343e6c380c881c | .git\objects\fb\a86a334abe0cdef080377ccb8bbac05d9233e5 |
.git\objects\fc\67f93c709f3431c7dc9f8a96ab70b6153b0979 | .git\objects\fd\265c22711eba5baa4506c5fd96576adc204241 |
.git\objects\fd\b5b370c2e812a6597ff8b782c7e09c10a3e85b | .git\objects\fe\65f13afa5910a655284a3537914d96419ba837 |
.git\objects\fe\7f0f6f71ceb5d1632ae7c71aefe124d6985f83 | .git\refs\heads\docs\claude-md |
.git\refs\heads\fix\ci-semgrep-zap | .git\refs\heads\fix\ci-workflows | .git\refs\heads\main |
.git\refs\remotes\origin\HEAD | .git\refs\remotes\origin\dependabot\github_actions\actions\checkout-7.0.1 |
.git\refs\remotes\origin\dependabot\github_actions\actions\setup-python-7.1.0 |
.git\refs\remotes\origin\dependabot\github_actions\trufflesecurity\trufflehog-3.99.3 |
.git\refs\remotes\origin\dependabot\github_actions\zaproxy\action-baseline-0.15.0 |
.git\refs\remotes\origin\docs\claude-md | .git\refs\remotes\origin\fix\ci-semgrep-zap |
.git\refs\remotes\origin\fix\ci-workflows | .git\refs\remotes\origin\main | .gitattributes | .github\CODEOWNERS |
.github\dependabot.yml | .github\workflows\build-exe.yml | .github\workflows\ci.yml |
.github\workflows\security-scan.yml | .github\workflows\trufflehog.yml | .github\workflows\zap.yml | .gitignore |
.gitleaks.toml | .semgrepignore | .zap\rules.tsv | CHANGELOG.md | CLAUDE.md | LIVE_VALIDATION.md | README.md |
SECURITY.md | build_exe.bat | constraints.txt | docs\CIS_COVERAGE.md | docs\PERMISSIONS.md | docs\TROUBLESHOOTING.md
| docs\UAT.md | docs\UAT_REVIEW.md | entra_posture_gui.py | entra_posture_scan.py | entra_scan__init__.py |
entra_scan\auth.py | entra_scan\batch.py | entra_scan\checks__init__.py | entra_scan\checks\apps.py |
entra_scan\checks\authn.py | entra_scan\checks\conditional_access.py | entra_scan\checks\devices.py |
entra_scan\checks\extended.py | entra_scan\checks\governance.py | entra_scan\checks\groups.py |
entra_scan\checks\identity_protection.py | entra_scan\checks\manual.py | entra_scan\checks\privileged.py |
entra_scan\checks\tenant.py | entra_scan\checks\users.py | entra_scan\cli.py | entra_scan\clouds.py |
entra_scan\context.py | entra_scan\export.py | entra_scan\graph.py | entra_scan\gui.py | entra_scan\metadata.py |
entra_scan\models.py | entra_scan\permissions.py | entra_scan\postprocess.py | entra_scan\report.py |
entra_scan\runner.py | requirements.txt | tests\conftest.py | tests\fake_tenant.py | tests\fuzz.py |
tests\report_dom_shim.js | tests\test_checks.py | tests\test_features.py | tests\test_misc.py |
tests\test_postprocess.py | tests\uat.py | tests\uat_browser.py | tests\uat_gui.py | tests\uat_gui_advanced.py |
tools\check_links.py | tools\gen_docs.py | tools\make_sample_report.py | tools\sast.py | tools\secret_scan.py |
tools\semgrep_pdf.py | tools\setup_app_registration.ps1

Appendix C - scan log (tail)

```
be interpreted as '/.github/workflows' to comply with the Semgrepignore v2 and Gitignore specifications. To make this
pattern permanently unanchored, edit rule
home.claude.sast.semgrep-rules.yaml.github-actions.security.audit.third-party-action-not-pinned-to-commit-sha and
change it to '**/.github/workflows'. To confirm the anchored behavior and avoid this warning, change it to
'/.github/workflows'.


■■■■■■■■■■■■■■■■
■ Scan Status ■
■■■■■■■■■■■■■■■■
Scanning 70 files tracked by git with 966 Code rules:

Language Rules Files Origin Rules
■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■ ■■■■■■■■■■■■■■■■■■
<multilang> 233 70 Custom 966
python 370 46
yaml 94 3
js 171 1

Rule home.claude.sast.semgrep-rules.yaml.github-actions.security.audit.third-party-action-not-pinned-to-commit-sha
contains an include pattern '.github/workflows' that will soon be interpreted as '/.github/workflows' to comply with
the Semgrepignore v2 and Gitignore specifications. To make this pattern permanently unanchored, edit rule
home.claude.sast.semgrep-rules.yaml.github-actions.security.audit.third-party-action-not-pinned-to-commit-sha and
change it to '**/.github/workflows'. To confirm the anchored behavior and avoid this warning, change it to
'/.github/workflows'.
```

```
■■■■■■■■■■■■■■■■■
■ Scan Summary ■
■■■■■■■■■■■■■■■■■
■ Scan completed successfully.
• Findings: 94 (94 blocking)
• Rules run: 866
• Targets scanned: 70
• Parsed lines: ~100.0%
• Scan skipped:
■ Files matching .semgrepignore patterns: 12
• For a detailed list of skipped files and lines, run semgrep with the --verbose flag
Ran 866 rules on 70 files: 94 findings.
exit 0
```

Reproduce: git clone https://github.com/semgrep/semgrep-rules; semgrep scan --metrics=off --config semgrep-rules/python --config semgrep-rules/generic --config semgrep-rules/javascript --config semgrep-rules/yaml --config semgrep-rules/bash --json -o semgrep.json .